



POLITECNICO DI TORINO

Master's Degree in Cybersecurity
LM-32 (DM270)

Master's Degree Thesis

SkillSecurer: Detecting and Patching Prompt-Injection Vulnerabilities in AI Agent Skills

Supervisor

Marco MELLIA
Nikhil JHA

Candidate

Donato MECCA

ACADEMIC YEAR 2025/2026

Summary

Artificial intelligence assistants are increasingly deployed as agents: rather than only answering questions, they act on a user’s behalf, executing commands, editing files, sending emails, and booking services. To configure an agent for a specific task, a mechanism known as a *skill* has become common in the last few years. A skill is a text file, written almost entirely in natural language, that specifies how the agent should behave in a given situation, such as planning a trip, replying to a certain type of email, or maintaining a calendar. No programming is required: the instructions are written as they would be for a human assistant, and the agent executes them accordingly.

This simplicity has contributed to the popularity of skills. Public marketplaces now distribute them in a manner comparable to mobile application stores: any author can publish a skill, and any user can install one with a single action; the most widely used skills have been downloaded millions of times. Unlike a mobile application, however, a skill is not subject to any automated review process prior to publication, and no widely adopted tool verifies what its instructions actually direct the agent to do. A malicious or careless author can embed, among otherwise legitimate instructions, a statement that causes the agent to perform a harmful action, such as transmitting private data to an external address, deleting files, or omitting a confirmation step before a sensitive operation. Because the agent executes instructions as written, and has no mechanism for distinguishing an author’s legitimate instruction from an injected one, it carries out both with equal reliability.

Contribution

This thesis addresses this problem by presenting **SkillSecurer**, a system that analyses a skill file, identifies the specific instruction responsible for a vulnerability, and produces a corrected version of the file that removes the vulnerability while preserving the rest of its content unchanged. Unlike scanners that report only a file-level classification, SkillSecurer localises each finding to the exact text span responsible for it, and its output can be verified directly by inspecting the removed or rewritten text.

Evaluation methodology

Constructing such a detector, however, addresses only part of the problem. Establishing whether a detector performs reliably requires an evaluation methodology, since a high nominal detection rate can result either from flagging most inputs indiscriminately or from testing exclusively on straightforward cases. This thesis evaluates SkillSecurer along three complementary dimensions.

The first dimension is *detection accuracy against known ground truth*. A component of the system, RedInjector, takes a benign skill and inserts a malicious instruction into it, at a controlled level of difficulty, while recording the exact location and content of the inserted text; a separate, externally curated benchmark of labelled injections is used alongside it. Together, these two labelled sources make it possible to determine not only whether SkillSecurer flags the file, but whether it identifies the specific instruction that was inserted, rather than an unrelated portion of the file.

The second dimension, *execution-based validation*, tests whether an inserted instruction actually causes an agent to perform the corresponding action, rather than only appearing malicious on inspection. An isolated sandbox environment executes a real AI agent three times on the same legitimate user request: once on the original skill, once on the injected version, and once on the version patched by SkillSecurer. Comparing the outcomes across the three executions establishes whether the attack succeeds on the unprotected skill, whether the patch prevents it, and whether the patch preserves the agent’s ability to complete the legitimate task; a correction that prevents the attack at the cost of the task’s functionality would not constitute an adequate solution.

The third dimension, the *in-the-wild audit*, evaluates SkillSecurer on unmodified, publicly published skills: several hundred of the most widely installed skills from a public marketplace were analysed to determine which issues the detector identifies in practice, and whether these findings are confirmed by independent human review.

Results

On the controlled benchmarks with known ground truth, the detector identifies nearly every inserted attack and localises the responsible instruction correctly in the large majority of cases, outperforming several previously published scanning tools evaluated on the same data. Under execution-based validation, the proportion of attempts that succeed against the corrected skill falls to 0.9%, compared to 40.9% on the unprotected skill, while the agent’s ability to complete the legitimate task is preserved.

An additional finding emerged from the in-the-wild audit. Changing only the underlying language model used by the detector produces markedly different outcomes on unlabelled, real-world content: one configuration flags 17.6% of skills as suspicious, while another flags 62.6% of the same files. This indicates that a

favourable result on a controlled benchmark does not, by itself, establish how a detector will behave on unlabelled data. On unmodified, publicly available skills containing no known injected vulnerability, the detector flags 34.6% as containing a genuine issue; independent human review confirms 85.1% of these findings as valid.

The work further includes a direct comparison against several previously published skill-security scanners. This comparison identifies a limitation common to approaches based on fixed lists of keywords or patterns (for example, the presence of a network command or a term related to system permissions): such tools tend either to miss attacks phrased in a more subtle, conversational manner, or to flag nearly every skill as suspicious regardless of content, which renders their output impractical without further manual review. The approach adopted in this thesis, which evaluates the concrete effect of each instruction within the context of the specific skill rather than matching isolated keywords, is more effective in precisely the cases where contextual reasoning is required.

Conclusions

This work has limitations that suggest directions for further research, including a more systematic study of how the choice of underlying language model affects each component of the system, and an extension of the present analyses to a larger set of real-world skills. Overall, this thesis demonstrates that an automatic review tool for AI agent skills can be built, and establishes a methodology for evaluating how reliably such a tool performs. This is a question of increasing relevance as AI agents gain greater autonomy and the skills that direct them become more widespread and less scrutinised.